MediBook Hospital Appointment Portal - Stakeholder Requirements

1. Patient accounts

The system shall allow patients to register using an email address and a mobile number.

The system must verify a patient's email address by sending a confirmation link before the account is activated.

Passwords must be at least 12 characters long and contain at least one number and one symbol.

The system shall require every password to be a minimum of 12 characters, including at least one number and one symbol.

Patients should be able to log in with their email address and password.

The system shall lock an account for 30 minutes after 5 consecutive failed login attempts.

Patients must be able to reset a forgotten password through an email link that expires after 30 minutes.

2. Appointment booking

Patients shall be able to search for doctors by name, specialty, and location.

The system must let patients book, reschedule, and cancel appointments online.

Patients must be able to cancel an appointment up to 2 hours before its start time.

Patients shall not be allowed to cancel an appointment within 24 hours of its start time.

The system shall prevent two patients from booking the same doctor at the same time slot.

The system shall send an SMS reminder to the patient 24 hours before every appointment.

The booking process should be simple and user-friendly.

3. Doctors and staff

Doctors shall be able to define their weekly availability and mark days of leave.

Receptionists must be able to book appointments on behalf of walk-in patients.

The system shall allow doctors to view the list of their appointments for the day.

Doctors must be able to add consultation notes to a patient's record after each visit.

Only the treating doctor and authorised administrators may view a patient's consultation notes.

Administrators shall be able to add, edit, and deactivate doctor profiles.

4. Payments and reporting

The system shall support online payment of consultation fees by credit card, debit card, and UPI.

Payment data must be handled in compliance with PCI DSS.

The system shall issue a PDF invoice for every completed payment.

Refunds should be processed quickly when an appointment is cancelled.

The system shall provide reports.

5. Notifications and integrations

The system must send transactional emails through an SMTP service.

The system shall integrate with an SMS gateway to deliver notifications.

The system shall be integrated with the hospital's existing laboratory information system.

6. Performance, security and reliability

The system should be fast.

Search results must be displayed within 2 seconds for 95 percent of requests.

The system shall support at least 2,000 concurrent users.

All patient data must be encrypted in transit using TLS 1.2 or higher and encrypted at rest.

The system shall be available 99.9 percent of the time, excluding scheduled maintenance.

User sessions shall expire after 15 minutes of inactivity.

User sessions must remain active until the user explicitly logs out.

The system shall keep an audit log of every access to patient records for at least 7 years.

The system must comply with applicable healthcare data protection regulations.

The web interface shall work on the latest versions of Chrome, Firefox, Safari, and Edge, including mobile screens.

Daily database backups must be taken and retained for 30 days.